

Postal address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1 (13)

The Discrimination Ombudsman

Decision following supervision under the
Data Protection Regulation against
The Discrimination Ombudsman
Contents

Decision of the Swedish Authority for Privacy Protection

.....	2
Account of the supervision case	2
Reasoning for the decision	2
Applicable provisions, etc.	2
Data protection responsibility	3
Security in the processing of personal data collected via the DO's web form	4
DO's information in the incident report	4
DO's information in the supervision case, etc.	4
IMY's assessment	7
Choice of intervention	9
Applicable provisions, etc.	9
DO's information	10
IMY's assessment	10
.....	10
Administrative fine to be imposed	10
Amount of the administrative fine	11
How to appeal	13
.....	13

Case number:
DI-2021-8354
Your case number:
LED 2021/488
Date:
2025-04-23

Swedish Authority for Privacy Protection
Case number: DI-2021-8354
2 (13)
Date: 2025-04-23

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection finds that the Discrimination Ombudsman has processed personal data in violation of Article 32.1 of the Data Protection Regulation by failing to take appropriate technical and organizational measures to ensure an adequate level of security for personal data when using the web form for tips and complaints about discrimination during the period from September 1, 2020, to September 17, 2021.

The Swedish Authority for Privacy Protection decides, pursuant to Chapter 6, Section 2 of the Data Protection Act and Articles 58.2 and 83 of the Data Protection Regulation, that the Discrimination Ombudsman shall pay an administrative fine of 100,000 (one hundred thousand) Swedish Krona for the violation of Article 32.1 of the Data Protection Regulation.

Account of the supervision case

The Swedish Authority for Privacy Protection (IMY) decided on October 6, 2021, to initiate supervision against the Discrimination Ombudsman (DO) following DO's report on a personal data incident on September 20, 2021 (IMY's case PUI-2021-4142). The purpose of the supervision is to examine DO's processing of personal data in connection with the authority's collection and storage of personal data when individuals use DO's web form for tips or complaints about discrimination. The supervision has been conducted as an inspection at DO on October 20, 2021, followed by written proceedings. IMY's examination in the case has been limited to assessing whether DO has complied with the obligation to take appropriate security measures according to Article 32.1 of the Data Protection Regulation for personal data collected via the web form for tips and complaints about discrimination during the period from September 1, 2020, to September 17, 2021.

Reasoning for the decision

Applicable provisions, etc.

According to Article 4.7 of the Data Protection Regulation, the data controller refers to a natural or legal person, public authority, institution, or other body that alone or jointly with others determines the purposes and means of the processing of personal data. If the purposes and means of the processing are determined by Union law or the national law of the Member States, the data controller or the specific criteria for how they are to be designated may be provided for in Union law or in the national law of the Member States.

Processing of personal data must comply with the fundamental principles in Article 5 of the Data Protection Regulation. Article 5.2 states the accountability principle, meaning that the data controller must be responsible for and be able to demonstrate compliance with the fundamental principles.

1 Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

2 The Act (2018:218) with supplementary provisions to the EU Data Protection Regulation.

Data Protection Authority

Reference Number: DI-2021-8354

3 (13)

Date: 2025-04-23

Special categories of personal data are listed in Article 9.1 of the General Data Protection Regulation, so-called sensitive personal data. These consist of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or membership in a trade union, as well as the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health, or data concerning a natural person's sex life or sexual orientation.

According to Article 32.1 of the General Data Protection Regulation, both the data controller and the data processor must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of the processing. In assessing which technical and organizational measures are appropriate, the data controller and the data processor shall take into account the latest developments, the implementation costs, and the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons.

According to Article 32.1, appropriate safeguards, where appropriate, include:

- a) pseudonymization and encryption of personal data,
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services,
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, and

d) a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

According to Article 32.2 of the General Data Protection Regulation, in assessing the appropriate level of security, special consideration shall be given to the risks posed by the processing, in particular the risk of accidental or unlawful destruction, loss, or alteration, or unauthorized disclosure of or access to personal data that has been transmitted, stored, or otherwise processed.

Recital 75 of the General Data Protection Regulation states that in assessing the risk to the rights and freedoms of natural persons, various factors should be taken into account. Among other things, it mentions personal data subject to confidentiality, data concerning health or sex life, whether the processing involves personal data concerning vulnerable natural persons, particularly children, or whether the processing involves a large amount of personal data and concerns a large number of data subjects. Recital 76 states that the likelihood and severity of the risk to the rights and freedoms of the data subject should be determined based on the nature, scope, context, and purposes of the processing. The risk should be assessed based on an objective evaluation, through which it is determined whether the processing involves a risk or a high risk.

Data Controller

The Data Ombudsman (DO) has stated that the authority is the data controller for the personal data collected via the web form in accordance with what the DO has indicated in the notification of the personal data incident.

According to the Data Protection Authority (IMY), the investigation in the matter supports that the DO determines the purposes and means of the relevant personal data processing. IMY therefore shares the DO's assessment that the DO is the data controller according to Article 4.7 of the General Data Protection Regulation for

Swedish Data Protection Authority

Diary Number: DI-2021-8354

4 (13)

Date: 2025-04-23

Processing of personal data collected via the DO's web form for tips or complaints regarding discrimination.

That DO is the data controller means that the authority has a responsibility to ensure and demonstrate that personal data is processed in accordance with applicable data protection regulations, see Articles 5.1 and 5.2 of the General Data Protection Regulation, the so-called accountability principle.

Security in the processing of personal data collected via DO's web form
DO's information in the incident report

In DO's report of a personal data incident on September 20, 2021, the authority describes the incident as an unauthorized disclosure of personal data about individuals who submitted tips or complaints via a web form. It is stated that an outsider or a registered individual informed DO about the incident. The number of registered individuals affected by the incident is estimated by DO to be between 101 and 1,000.

DO's information in the supervisory matter, etc.

DO's mandate is regulated by the Act (2008:568) on the Discrimination Ombudsman, the Discrimination Act (2008:567), the Parental Leave Act (1995:584), and the Ordinance (2008:1401) with instructions for the Discrimination Ombudsman. There is specific confidentiality for DO's operations in Chapter 33, Section 1 of the Public Access to Information and Secrecy Act (2009:400), OSL.

On September 22, 2021, DO published the news "DO shuts down the web form for tips and complaints," indicating that DO had become aware of a security issue in its web environment.

On DO's website, there was a web form where individuals could submit tips or complaints regarding discrimination. The form was available from September 1, 2020, until DO became aware that there might be a security issue related to the form. The form was closed on September 17, 2021.

When the reporter had filled in all the information, they could see their responses on a summary page and then click send. The information in the completed web form was, after the individual chose to

submit the information, transferred encrypted to DO's case management system.

In September 2021, DO received inquiries from a person who had used the web form. The inquiries indicated that there might be a security issue with the form. Therefore, DO immediately initiated an investigation to determine the cause of the potential problem. The investigation showed that there was no security issue with the web form itself. The problem was caused by a security setting – which masks information in free text fields – in the analysis tool (see below) not functioning as DO had assumed in relation to the summary page for the web form.

From the aforementioned form for tips or complaints regarding discrimination, the following was stated: "Your tip or complaint is important for our work against discrimination. With the help of the information you provide, we can identify problems in various areas of society where we need to act to drive development, provide guidance, and increase awareness of risks of discrimination or where we need to act to change..."

Swedish Data Protection Authority

Diary Number: DI-2021-8354

5 (13)

Date: 2025-04-23

the legislation. We therefore use the information to encourage more people to comply with the law and not primarily to resolve situations for individual persons.

Everything you report here will become a public document that can be requested by the public and disclosed after a confidentiality assessment. We therefore recommend that you do not provide more personal data than is necessary in the free text fields."

The form included, among other things, a free text field where the informant can describe what has happened. The following text was present in connection with the free text field.

"Describe the event(s) that lead you to submit a tip or complaint to the DO. Please specify the role of the person who has subjected someone to discrimination (for example, manager, teacher, nurse, or caseworker) and whether the discrimination has occurred on multiple occasions. Do not name individuals."

A mandatory field in the web form required the informant to select from predefined options related to discrimination, indicating which option(s) correspond to the events described by the informant. Among these options were discrimination related to ethnic origin, disability, gender identity and expression, religion or other belief, and sexual orientation. Another mandatory field was to indicate from predefined options whether the tip or complaint concerns harassment, sexual harassment, or reprisals.

The form also included a free text field for additional information or comments with the instruction that other relevant information not provided earlier in the form could be indicated here. Under "Your contact details" in the form, it was stated that it is voluntary to fill in personal data in the form, and that the informant does not need to provide their contact details or other personal data for the DO to receive and utilize the tip or complaint. The informant could provide an email address or phone number or remain anonymous. It was mandatory to indicate whether the tip or complaint concerns events that the informant has personally been subjected to or if the tip or complaint concerns events that others have been subjected to.

Furthermore, there was an instruction for filling out the web form where the submitter was recommended not to provide more personal data than is necessary in the free text fields.

The purpose of collecting personal data in the web form was for the DO to obtain material for conducting supervision in accordance with the DO's mandate and to conduct knowledge acquisition as part of the mandate.

The reports could contain sensitive personal data, but the DO had worked on a development assignment prior to the launch of the web form to reduce the number of personal data, as stated in the DO's Assignment Directive for the review of the use of the term reports in the DO's operations, dated January 20, 2020. The DO worked to design the questions in the web form in a way that minimizes the request for personal data, and especially sensitive personal data, based on the principle of data minimization.

On the DO's website, an analysis tool from a company, a data processor, has been installed. There

was a data processing agreement. When the web form was introduced
Swedish Data Protection Authority
Diary Number: DI-2021-8354
6 (13)
Date: 2025-04-23

the analysis tool already existed. The tool recorded and saved various data points about the user's session during their visit to the website (so-called "recordings"), for example, how a user navigates the website. In this way, the Swedish Data Protection Authority (DO) could analyze how the website was used. The purpose of the analysis was to optimize and improve the functionality of the website. The tool has been present throughout DO's website, including on the page with the web form. The analysis tool worked by recording a random selection of visits or sessions spread throughout the day (25 percent of the traffic on the website).

DO used a security setting in the analysis tool that replaced information entered in free text fields with asterisks, i.e., star characters. The intention of this setting was that the data entered in the web form would not be visible in clear text in the analysis tool. The security setting functioned correctly in all free text fields of the web form. However, it did not function on the summary page of the form, except for the box for phone number or email address. DO's investigation showed that this was due to the analysis tool perceiving the summary page as any other webpage. It cannot be ruled out that the person who provided the information may have entered email address and/or phone number details in some other free text field.

Due to the fact that the function used by DO did not work for the summary page, personal data from the relevant form was transferred and stored with the data processor, which was not the intention. The data processor has informed DO that all communication between the analysis tool and the storage area was encrypted with TLS 1.2. The storage was encrypted with AES-256.

Internally at DO, only one authorized person had login credentials to the analysis tool. Examples of other measures at DO included that encryption was used both for the form and for the transfer to DO's registration function. The form was hosted on DO's own servers and behind a firewall.

During the relevant 12-month period, approximately 5,400 tips and complaints were received by DO, the majority of which came via the web form. DO's assessment is that the analysis tool transferred approximately 500 tips and complaints that could have contained personal data. A person could write anything from one page of free text to 40 pages of free text. Personal data about children under 18 years old could be present, for example, names of students. Other examples included names of employees at a specific workplace.

The data processor has confirmed in writing to DO that they have not accessed personal data or other information on the summary page. They have also informed that according to their data classification policy, only personnel with a real and actual operational need can access such information generated by the tool and only for support and maintenance. Access is granted based on a so-called "Change Request" and is reviewed and approved depending on the role.

At the time of the incident, DO had governing documents including the Information Security Policy and the Routine for Recording Systems Containing Personal Data. The latter document has been replaced in 2023 by the Routine for Handling Personal Data in Purchases. There are also now Guidelines for Data Protection, which codify and clarify how DO should work with data protection. Before the launch of the web form, DO conducted a risk analysis in

Swedish Authority for Privacy Protection
Diary Number: DI-2021-8354
7 (13)
Date: 2025-04-23

in accordance with applicable routine, and it was established prior to the launch that, among other things, the security setting in the analysis tool needed to be activated.

To ensure that the technical and organizational security measures that are decided upon are also implemented, the Data Protection Authority (DO) has a number of routines that contribute to monitoring. Contract managers continuously follow up on their agreements and engage in dialogue

with the supplier regarding any issues that need to be resolved, e.g., concerning personal data processing.

The Data Protection Officer conducts an annual follow-up of the authority's data protection work, where it is noted if there are any areas or issues that the DO must work on to further improve its data protection efforts. DO's employees are aware of the routines that exist within the authority and raise flags if something occurs that is not in accordance with these routines. For example, the DO acted immediately when an employee received inquiries indicating that there might be a problem with the web form. This demonstrates that the monitoring routines have functioned well, even regarding the web form.

After the files had been exported encrypted from the data processor to the DO, the DO provided further instructions to the processor that the files should be deleted at the processor's end. On December 15, 2021, the processor confirmed that they had deleted the files in accordance with the DO's instructions. The files that had been with the data processor can therefore be considered deleted at this time according to the DO. Content in the analysis tool was manually deleted by an employee at the DO. All deletion measures were completed by December 21, 2021. The DO terminated the agreement with the data processor on February 15, 2022. However, the tool was deactivated already on September 18, 2021.

IMY's Assessment

The processing has required a high level of security

The investigation shows that the DO, based on the authority's mandate regarding discrimination, has used a web form to collect personal data related to discrimination in the form of tips and complaints. This has been done by allowing the data subject to describe what has happened in free text fields and, as a mandatory requirement, indicate the type of discrimination intended through predefined options. Among these options were discrimination related to ethnic origin, disability, gender identity and expression, religion or other beliefs, and sexual orientation. The data subject of a tip or complaint could provide their email address or name. Personal data about children could occur, for example, names of students. Other examples of personal data included names of employees at a specific workplace. Tips and complaints could concern events that others than the submitter of the web form had been subjected to. The information could be subject to statutory confidentiality according to Chapter 33, Section 1 of the Public Access to Information and Secrecy Act (OSL).

The DO, as the data controller, is obliged to take appropriate security measures. In assessing the appropriate level of security, special consideration must be given to the risks that the processing entails, particularly from accidental or unlawful destruction, loss, or alteration, or to unauthorized disclosure of or unauthorized access to the personal data that has been transferred, stored, or otherwise processed, see Article 32.1 and 32.2 of the General Data Protection Regulation (GDPR). Ensuring appropriate security means that the security level must be adapted to the risks associated with the specific processing.

IMY notes that sensitive personal data according to Article 9.1 of the GDPR includes, among other things, personal data that reveals race or ethnic origin, religious or philosophical beliefs, health data, and data concerning a natural person's

Swedish Authority for Privacy Protection

Diary Number: DI-2021-8354

8 (13)

Date: 2025-04-23

Sexual life or sexual orientation. The web form could be used for tips or complaints regarding the grounds for discrimination, which include gender identity or expression, ethnic origin, religion or other beliefs, disability, and sexual orientation. Personal data linked to the grounds for discrimination often also constitutes sensitive personal data according to Article 9.1 of the General Data Protection Regulation. Processing that involves sensitive personal data generally entails higher risks. Furthermore, children's personal data deserve special protection, as children may be less aware of the relevant risks, consequences, and protective measures, as well as their rights regarding the processing of personal data.

IMY notes that DO has collected personal data, including sensitive personal data, that may be subject to confidentiality obligations. During the relevant period, approximately 5,400 tips or complaints were received, the majority of which came via the web form. The submitter of the form could write up to 40 pages of free text and could also describe events concerning individuals other than the submitter themselves. Data subjects who used the web form or other individuals mentioned in the web form can be considered to have a high expectation that unauthorized persons will not be able to access their personal data.

In summary, IMY assesses that the nature, scope, and context of the personal data processing have posed such risks that high demands must be placed on the security measures that need to be implemented according to Article 32.1 of the General Data Protection Regulation regarding the processing of personal data collected via the web form.

DO has not taken sufficient measures to protect the data

IMY finds that during the period from September 1, 2020, to September 17, 2021, there was a lack of a security setting that protected personal data on the summary page of the web form, with the exception of the fields for telephone number and email address. This led to personal data from the summary page of the web form being transferred to the data processor.

According to IMY, the mere fact that DO inadvertently transferred the relevant data to the data processor means that the data was, in fact, not protected against unauthorized disclosure. DO has also stated in its report of the personal data incident that the security incident consisted of unauthorized disclosure.

The investigation in the matter shows that DO had routines for, among other things, the registration of systems containing personal data and that DO decided to take a number of measures to protect personal data collected via the web form prior to its launch. Before the launch, DO noted, among other things, that the security setting in the analysis tool needed to be activated. However, it was not ensured that the setting functioned fully. The measures taken by DO were therefore not sufficient to protect the personal data from being disclosed to the data processor.

The ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services is, according to Article 32.1 b of the General Data Protection Regulation, a measure that may be appropriate in ensuring a security level that is suitable in relation to the risk. Another measure that may be appropriate in ensuring a security level that is suitable in relation to the risk is

3 The Discrimination Act (2008:567) aims to combat discrimination and otherwise promote equal rights and opportunities regardless of gender, gender identity or expression, ethnic origin, religion or other beliefs, disability, sexual orientation, or age.

4 Recital 38 of the General Data Protection Regulation.

Swedish Data Protection Authority

Diary Number: DI-2021-8354

9 (13)

Date: 2025-04-23

The risk is according to Article 32.1 d of the General Data Protection Regulation a procedure for regularly testing, examining, and evaluating the effectiveness of the technical and organizational measures intended to ensure the security of processing.

IMY notes that the Data Ombudsman (DO) took investigative measures when the DO received inquiries from an outsider indicating that there could be a security issue with the web form. Although the DO has stated that the authority has procedures for monitoring security measures, these procedures have not been sufficient for the DO to detect and address the security deficiency during the relevant period. According to IMY's assessment, the DO has thus lacked an effective systematic security effort from September 1, 2020, to September 17, 2021, which would have made it possible to detect the security deficiency and the unauthorized disclosure.

The DO has thus processed personal data in tips or complaints about discrimination on the summary page of the web form without sufficiently protecting the personal data against unauthorized disclosure during the relevant period. Therefore, the DO has not fulfilled its obligation as a data controller to implement appropriate technical and organizational measures that ensure a level of security appropriate to the risk in accordance with Article 32.1 of the General Data Protection Regulation.

Choice of Intervention

Applicable Provisions, etc.

In cases of violations of the General Data Protection Regulation, IMY has a number of corrective powers available under Article 58.2 a–j of the General Data Protection Regulation, including reprimands, orders, and administrative fines. Article 83.2 states that IMY shall impose administrative fines in addition to or instead of the other measures referred to in Article 58.2 depending on the circumstances of the individual case.

Each supervisory authority shall ensure that the imposition of administrative fines in each individual case is effective, proportionate, and dissuasive. This is stated in Article 83.1 of the General Data Protection Regulation.

Member States may establish rules regarding whether and to what extent administrative fines may be imposed on public authorities. This is indicated in Article 83.7 of the General Data Protection Regulation. According to Chapter 6, Section 2 of the Data Protection Act, IMY may impose fines on authorities for violations referred to in Articles 83.4, 83.5, and 83.6 of the General Data Protection Regulation, and Articles 83.1, 83.2, and 83.3 of the Regulation shall then apply.

Article 83.2 of the General Data Protection Regulation specifies the factors to be considered in determining whether an administrative fine should be imposed and what may affect the amount of the fine. Relevant to the assessment of the seriousness of the violation are, among other things, its nature, severity, and duration. The EDPB has adopted guidelines on the calculation of administrative fines under the General Data Protection Regulation aimed at creating a harmonized method and principles for calculating fines.⁵ The guidelines may be applied to the calculation of fines to be imposed on public authorities and bodies.⁶

5 EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR.

6 EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, point 10.

Swedish Data Protection Authority

Case Number: DI-2021-8354

10 (13)

Date: 2025-04-23

If it concerns a minor infringement, IMY may, according to Recital 148 of the General Data Protection Regulation, instead of imposing an administrative fine, issue a reprimand in accordance with Article 52.2 b of the Regulation.

DO's Information

DO has primarily stated the following regarding corrective measures.

The processing has not posed any risk of unauthorized disclosure or unauthorized access to the relevant data. The data has been transferred encrypted to the data processor and has been stored encrypted in the database. The information in the database consists solely of data points collected from the user's browser session. To access the data, it is required that the information is played back in the tool, which necessitates an active connection between the browser and the database. Therefore, the data has not been stored in a readable format and has also not been searchable. The data processor has furthermore confirmed to DO that no staff members have had access to the relevant data.

The processing has also not involved any external recipient, acting as a data controller, receiving the data for their own subsequent processing for their own purposes. This is because the data processor has processed the data as a data processor on behalf of DO within the framework of DO's data controller responsibilities and only according to DO's instructions. It can thus be established that in this case, there has not been uncontrolled disclosure of data to many recipients or public dissemination.

The processing has been limited in scope and has only concerned a few registered individuals. The relevant form was available on DO's website for a relatively limited time.

DO has taken protective measures to ensure the rights and freedoms of the data subjects before the web form for tips and complaints was launched. As soon as it became known that more data than intended was transferred to the data processor, DO removed the tool. DO also ensured that the data was deleted by the data processor.

If IMY assesses that DO has not fulfilled the requirements of Article 32.1 of the General Data Protection Regulation, the infringement should be regarded as a minor infringement where a reprimand is a sufficient corrective measure. This is particularly in light of the fact that the processing has, in practice, not posed any risk to the affected registered individuals and that DO has taken several measures in response to the incident.

If IMY still assesses that an administrative fine should be imposed, any potential infringement of the requirements of Article 32.1 of the General Data Protection Regulation should, in any case, be considered to have a very low level of severity for the reasons stated above.

IMY's Assessment

An administrative fine should be imposed

IMY has assessed that DO has processed personal data in violation of Article 32.1 of the General Data Protection Regulation.

The infringement has occurred because DO has processed personal data for over a year with an insufficient level of security. The insufficient level of security has led to

Integrity Protection Authority

Diary Number: DI-2021-8354

11 (13)

Date: 2025-04-23

unauthorized disclosure of personal data that could be sensitive or covered by confidentiality obligations. The Authority has, during this time, lacked the ability to detect the ongoing disclosure of the personal data. The Integrity Protection Authority assesses that this does not constitute minor violations as referred to in Recital 148 of the General Data Protection Regulation (GDPR).

The Court of Justice of the European Union has clarified that it is required for the data controller to have committed a violation intentionally or negligently for administrative fines to be imposed under the GDPR. The Court has stated that data controllers can be subject to fines for actions if they cannot be considered to have been unaware that the action constituted a violation, regardless of whether they were aware that they were disregarding the provisions of the GDPR.⁷

According to the principle of accountability, which is expressed in Article 5.2 of the GDPR, the entity responsible for processing personal data must ensure and be able to demonstrate that the processing is in compliance with the GDPR. The Integrity Protection Authority notes that the Authority is responsible for ensuring that personal data collected in its operations is processed in a manner that ensures an appropriate level of security. The Integrity Protection Authority has found that the Authority has not met the requirements set by the GDPR in these respects. The Authority cannot be considered to have been unaware that its actions constituted violations of the regulation. There are thus grounds for imposing an administrative fine on the Authority.⁸

Amount of the Fine

According to Chapter 6, Section 2 of the Data Protection Act, the fine for an authority shall be determined to a maximum of 5,000,000 kronor for violations referred to in Article 83.4 of the GDPR and to a maximum of 10,000,000 kronor for violations referred to in Articles 83.5 and 83.6. Violations of Article 32 are covered by the lower fine.

According to the EDPB's guidelines, the supervisory authority must assess whether the violation is of low, medium, or high severity according to Articles 83.2 a, b, and g of the GDPR.⁹ In assessing the severity of the violation, the Integrity Protection Authority takes into account the following circumstances.

The absence of a security setting for the compilation of free-text fields and the Authority's lack of ability to detect the transfer of the data led to a personal data incident that lasted for approximately one year,

i.e., for an extended period. As mentioned above, the Integrity Protection Authority assesses that the mere fact that the personal data was transferred to the data processor constitutes unauthorized disclosure. The fact that it was a transfer to a data processor does not change this circumstance, especially considering that the Authority's intention was never for the data to be transferred to that data processor. The processing of personal data included descriptions of events related to discrimination associated with one or more grounds for discrimination. The processing involved approximately 500 tips and complaints that could contain personal data, and it was possible to write 40 pages of free text in the web form. Descriptions of events concerning discrimination are of a personal nature. Sensitive personal data has been involved in an operation where the data may also be covered by confidentiality obligations.

7 Judgment of the Court of Justice of the European Union in Case C-683/21 *Nacionalinis visuomenės sveikatos centras prie Sveikatos apsaugos ministerijos v. Valstybinė duomenų apsaugos inspekcija* of December 5, 2023, paragraph 81, and judgment in Case C-807/21 *Deutsche Wohnen* of December 5, 2023, paragraph 76.

8 See also the assessment of negligence in the Administrative Court of Appeal in Stockholm's judgment on March 11, 2024, in case 2829-23 p.12.

9 EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, paragraph 60.

Swedish Authority for Privacy Protection

Case Number: DI-2021-8354

12 (13)

Date: 2025-04-23

Individuals who have been subjected to discrimination, such as children and employees, are considered to have a legitimate expectation of high confidentiality and that their personal data will not be disclosed.

The violation in the form of inadequate technical and organizational measures has posed a risk that unauthorized persons may gain access to the personal data of the registered individuals.

IMY assesses, in summary, that the violation should be regarded as more serious than if the above circumstances had not existed. However, circumstances have also emerged in the case that suggest the violation should be assessed as less serious.

IMY notes that the DO, at the time of the violation, had implemented a number of appropriate technical and organizational measures; for example, the transfer of data from the web form to the data processor was conducted through encrypted transmission. Thus, it was not an uncontrolled disclosure where the data was, for instance, accessible via the internet. It can also be noted that the transfers in this case were made to an entity that processes the data as a data processor in relation to the DO.

Furthermore, the DO had recommended in the instructions for filling out the web form that the submitter should not provide more personal data than necessary in the free text fields. The DO had also identified the security setting in the analysis tool as an appropriate security measure in the preparations for the launch of the web form and activated it with the intention that it would also function concerning the summary page.

It has also not emerged that the data processor actually accessed the personal data that was transferred.

In a comprehensive assessment against the background of the above circumstances, IMY assesses that this constitutes a violation of Article 32.1 of the General Data Protection Regulation of low severity. IMY will also assess whether there are any aggravating or mitigating circumstances that may affect the size of the administrative fine.

IMY notes that the DO took measures after the incident by ceasing the collection of personal data via the web form for tips and complaints and by contacting the data processor to investigate the incident. The DO also ensured that the processor ceased processing the personal data. Information about the incident was provided by the DO publishing a news item on the authority's website. IMY assesses that these measures cannot be considered to go beyond what is expected of the DO in this case.

Therefore, the measures taken do not constitute a mitigating factor according to IMY.

IMY assesses that, in addition to the circumstances considered above, there are no aggravating or

mitigating circumstances that affect the administrative fine.

In light of the seriousness of the violations, IMY determines the administrative fine to be 100,000 kronor for the violation. IMY assesses that this amount is effective, proportionate, and deterrent.

Swedish Authority for Privacy Protection

Case Number: DI-2021-8354

13 (13)

Date: 2025-04-23

This decision has been made by the unit manager Linn Sandmark after presentation by the department director Suzanne Isberg. In the final processing, the IT and information security specialist Petter Flink and the department lawyer Andreas Persson have also participated.

Linn Sandmark

Attachment

Information on payment of the administrative fine

Copy to

dataskyddsbud@do.se

How to appeal

If you wish to appeal the decision, you should write to IMY. Indicate in the letter which decision you are appealing and the change you are requesting. The appeal must be received by IMY within three weeks from the day you received the decision. However, if you are a party representing the public, the appeal must be submitted within three weeks from the day the decision was announced. If the appeal has been submitted in a timely manner, IMY will forward it to the Administrative Court in Stockholm for examination.

You may email the appeal to IMY if it does not contain any sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.